SECCIÓN 4.11

TTPs, MITRE ATT&CK y Kill Chain aplicados al SOC

Temas de esta sección:

- Qué son TTPs: Tácticas, Técnicas y Procedimientos
- Qué es MITRE ATT&CK y para qué sirve en SOC
- MITRE no es una conclusión automática
- Tácticas frecuentes: Execution, Persistence, C2, Exfil, Impact
- Qué es la Kill Chain y cómo usarla para ordenar investigaciones
- MITRE vs Kill Chain: se complementan
- Cómo documentar con TTPs sin convertirlo en algo mecánico

TTP: Tactics, Techniques and Procedures — una forma de describir cómo actúa una amenaza por comportamiento, no por indicadores:

TÁCTICA	El objetivo del atacante en esa etapa.	*Ejemplo: Persistencia / Movimiento Lateral / Exfiltración*
TÉCNICA	La forma general en que intenta lograr ese objetivo.	*Ejemplo: Scheduled Task / Remote Services / Exfiltration Over Web Service*
PROCEDIMIENTO	Cómo lo hizo en este caso concreto. Lo que vemos en el caso real.	*Ejemplo: Creó tarea OneDriveUpdate ejecutando C:\Public\svcupdate.exe cada 10 min*

¿Por qué TTPs? Un hash puede cambiar. Un dominio puede cambiar. Pero el atacante puede seguir usando PowerShell para descargar payloads. Los TTPs son más estables que los indicadores.

Las 12 tácticas principales y cómo se ven en el trabajo diario del analista SOC:

Initial Access	Execution	Persistence	Privilege Escalation
Correo con adjunto, phishing de credenciales	PowerShell iniciado por Word, script ejecutado	Tarea programada, Run Key, servicio nuevo	Uso de cuenta admin, bypass de controles
Defense Evasion	**Credential Access**	**Discovery**	**Lateral Movement**
Comando codificado -enc, proceso legítimo abusado	Chrome Login Data accedido, LSASS dump	whoami, net view, nltest, ipconfig, arp -a	SMB, RDP, WinRM, PsExec hacia múltiples hosts
Command & Control	**Collection**	**Exfiltration**	**Impact**
Beaconing, dominio raro, conexión periódica	Acceso a carpetas sensibles, compresión 7z	Upload a cloud, correo externo, DNS tunneling	Cifrado masivo, eliminación shadow copies, ransom note

4.11 | Kill Chain + MITRE: ejemplo de cadena completa

Un mismo incidente mapeado con Kill Chain y MITRE ATT&CK:

1	Usuario recibe correo con adjunto malicioso	Delivery	Initial Access
2	WINWORD.EXE ejecuta powershell.exe -enc	Exploitation	Execution
3	PowerShell descarga update.exe	Installation	Execution
4	Crea tarea programada OneDriveUpdate	Installation	Persistence
5	Conexiones cada 60s a sync-check-cloud.net	C2	Command & Control
6	whoami, net view, nltest ejecutados	Actions	Discovery
7	SMB a 37 hosts internos	Actions	Lateral Movement

El modelo sirve para ordenar preguntas y comunicar mejor — no para reemplazar el criterio ni para confirmar incidentes automáticamente.

Son dos marcos distintos con foco diferente. Usados juntos dan una visión más completa del incidente:

Cyber Kill Chain (Lockheed Martin)

7 fases secuenciales:
1. Reconnaissance
2. Weaponization
3. Delivery
4. Exploitation
5. Installation
6. C2
7. Actions on Objectives

✔️ Útil para narrar el incidente como una historia lineal
✔️ Bueno para comunicar con management
⚠️ Menos granular para técnicas específicas

MITRE ATT&CK

12+ tácticas con cientos de técnicas y sub-técnicas.
Cada técnica tiene ID (T1059.001), ejemplos y mitigaciones.

✔️ Más granular y técnico
✔️ Permite buscar detecciones y mitigaciones específicas
✔️ Base para reglas de detección en SIEM/EDR
⚠️ Puede volverse mecánico si se usa sin evidencia

En la práctica: Kill Chain para ordenar la narrativa del incidente + MITRE para referenciar técnicas específicas en el ticket o escalamiento.

MITRE como soporte al análisis, no como reemplazo. La técnica debe acompañar la evidencia:

Documentación incompleta — MITRE sin evidencia:

```
"T1059.001."  →  No explica nada. No hay evidencia. No hay decisión.
```

Documentación completa — MITRE como referencia:

```
"Se observó ejecución de PowerShell iniciada por WINWORD.EXE con parámetros de ocultamiento y comando codificado.
Posteriormente se
identificó conexión HTTPS hacia dominio externo y creación de update.exe en C:\Users\Public\. La secuencia es compatible
con ejecución
inicial mediante documento y posible descarga de payload, asociada a MITRE ATT&CK T1059.001 (PowerShell). Se recomienda
escalamiento."
```

El ID MITRE acompaña la evidencia, no la reemplaza. Sin evidencia, el ID no dice nada.